

Lab Experiment - 02

Cross-site Scripting (XSS)

Objective: To learn about XSS attacks and how to mitigate them.

Tools: DVWA

What is XSS?

Cross-Site Scripting (XSS) is a type of security vulnerability commonly found in web applications. It allows attackers to inject malicious scripts into content that other users will see. This can lead to a variety of harmful outcomes, such as stealing session cookies, redirecting users to malicious sites, or defacing web pages. Here are the main types of XSS attacks:

1. Stored XSS: The malicious script is permanently stored on the target server, such as in a database, and is served to users who visit the affected page.

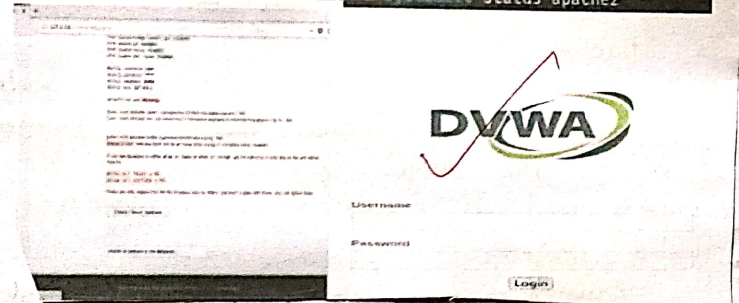
For example, if a user posts a comment containing a malicious script, and this comment is displayed to others, it's a stored XSS attack.

2. Reflected XSS: The malicious script is reflected off a web server, usually via a URL or request parameter. This type of XSS is often used in phishing attacks. The malicious payload is sent to

```

root@kali: ~# git clone https://github.com/digininja/DVWA.git
[sudo] password for kali:
root@kali: ~# cd /var/www/html
root@kali: /var/www/html# mv DVWA /var/www/html/DVWA
root@kali: /var/www/html/DVWA# cd config
root@kali: /var/www/html/DVWA/config# systemctl start apache2
root@kali: /var/www/html/DVWA/config# systemctl status apache2
apache2.service - The Apache HTTP Server
Loaded: loaded (/lib/systemd/system/apache2.service; disabled; preset: disabled)
Active: active (running) since Wed 2024-09-04 12:27:20 EDT; 56s ago
root@kali: /var/www/html/DVWA/config# cd /etc/php
root@kali: /etc/php# cd 8.2
root@kali: /etc/php/8.2# cd apache2
root@kali: /etc/php/8.2/apache2# mv php.ini php.ini.bak
root@kali: /etc/php/8.2/apache2# mv mousepad php.ini
root@kali: /etc/php/8.2/apache2# systemctl restart apache2
root@kali: /etc/php/8.2/apache2# systemctl status apache2

```



the server and then immediately reflected back to the user's browser.

3) DOM - based XSS: The vulnerability exists in the client-side code rather than on the server. In this case, the malicious script manipulates the DOM (Document Object Model) of the page, potentially altering how content is displayed or how the page interacts with the user.

How XSS Attacks Work?

1) Injection: The attacker injects a malicious script into a web application.

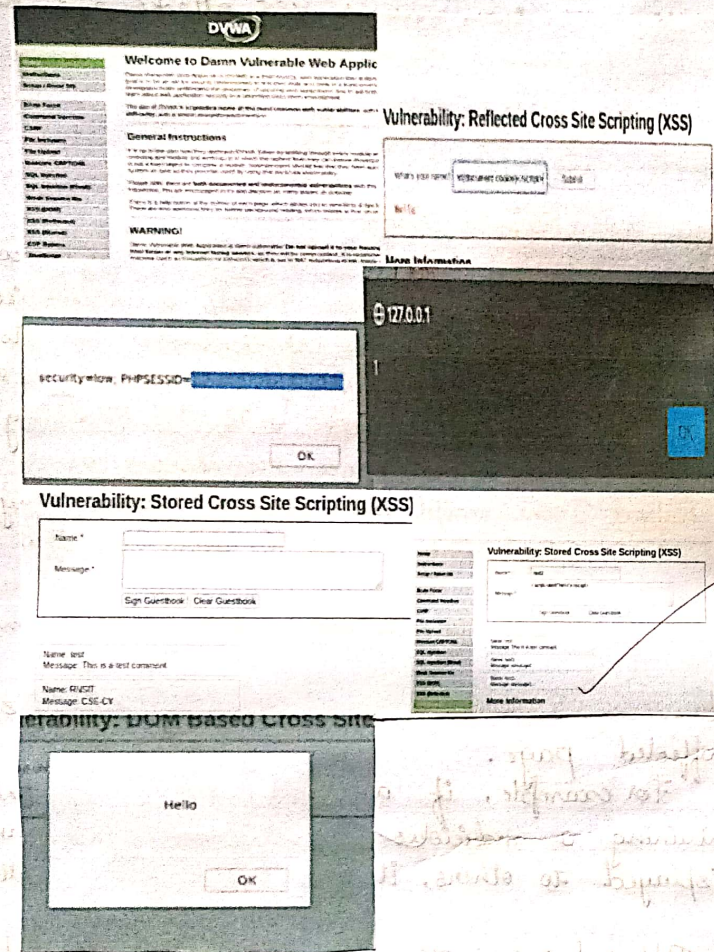
2) Execution: The injected script is executed in the context of the victim's browser, often with the same permissions as the user.

3) Impact: The script can perform actions such as capturing sensitive data, manipulating the user's view of the site, or redirecting the user to malicious sites.

Preventing XSS

1) Content Security Policy (CSP): Implement a CSP to restrict the sources from which scripts can be loaded and executed. This helps to minimize the impact of XSS attacks.

Staying informed about best practices and continuously reviewing and testing your applications are crucial steps in maintaining security against XSS vulnerabilities.



TOOL DVWA : DVWA, which stands for Damn Vulnerable Web Application, is a deliberately insecure web application designed to be used for educational and training purposes in the field of cybersecurity and ethical hacking. Created to provide a safe and controlled environment for learning about web application vulnerabilities and practicing penetration testing techniques, DVWA is not intended for use in production environments.

Installation of DVWA

Required Kali Linux, MySQL, Web Server Apache

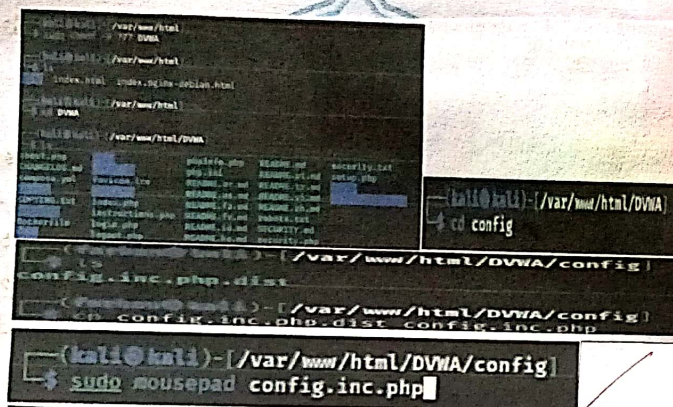
Step 1 : Download DVWA goto browser Google and type DVWA github then copy URL.

Step 2 : Goto terminal to download DVWA on local system and change the directory to run all web application.

Step 3 : If you're already a root user then no need to give sudo, otherwise provide the sudo at the beginning of the DVWA git link. change the downloaded DVWA into executable, give all the permission

Config.inc.php.dist got the default configuration, just create the copy of this file with .php in future if have any issues then copy of the default values will be available.

Step 4 : Open config file using vi and hit enter.



```

kali@kali: /var/www/html
$ cd DVWA
kali@kali: /var/www/html/DVWA
$ cd config
kali@kali: /var/www/html/DVWA/config
$ cp config.inc.php.dist config.inc.php
kali@kali: /var/www/html/DVWA/config
$ sudo mousepad config.inc.php
  
```

```

17 DVWA['db_host'] = 'localhost';
18 DVWA['db_server'] = getenv('DB_SERVER') ? '127.0.0.1' : 'localhost';
19 DVWA['db_database'] = 'dvwa';
20 DVWA['db_user'] = 'admin';
21 DVWA['db_password'] = 'password';
22 DVWA['db_port'] = '3306';

```

```

(hali@kali) ~ - ssh
$ sudo systemctl start mysql

(hali@kali) ~ - ssh
$ sudo systemctl status mysql

```

RNSIT

Step 5 : After opening the config file, make changes with dbuser = admin, dbpassword = password, save and close the file

Step 6 : Configure the database - first start the mysql

Step 7 : Login is done, after that fill the database.

Create the user : The user name and password should be same as config file and 127.0.0.1 is the loop back address.

Provide the privileges to the user.
Then provide exit and clear the screen.

Step 8 : Configure and start web server

Step 9 : Configure the server with php file.
Make the changes with php file with editor.
The fopen and include should be on condition.

Step 10 : Restart the apache2 server.

Step 11 : Goto browser and type url as 127.0.0.1 \ DVWA
Set the DVWA for the first time when it is used click on create.

Provide username as admin and password as password. Next click on create/open db, and login again.

Example : XSS Reflected.

Example : Get cookies information : Session ID (Using Burp
you can login to account without credentials)
with low security level.

Try with different security level - medium, high.

Stored : Example (1)

Example (2) Malicious script

DOM : no text box is available, only we can use here
is url

~~10~~ 10 p22110

```
(kali@kali)-[/var/www/html/DVWA/config]
$ sudo systemctl status mysql
(kali@kali)-[/var/www/html/DVWA/config]
$ sudo su
(root@kali)-[/var/www/html/DVWA/config]
$ mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 10.11.2-MariaDB-1 Debian n/a

MariaDB [(none)]> create database dvwa;
Query OK, 1 row affected (0.000 sec)

MariaDB [(none)]> create user 'admin'@'127.0.0.1' identified by 'password';
Query OK, 0 rows affected (0.088 sec)

Provide the privileges to this user
MariaDB [(none)]> grant all privileges on dvwa.* to 'admin'@'127.0.0.1';
Query OK, 0 rows affected (0.022 sec)
```